

GUJARAT TECHNOLOGICAL UNIVERSITY
ME - SEMESTER- 2 (New) • EXAMINATION – SUMMER - 2021

Subject Code:3725904**Date: 27 Aug 2021****Subject Name:Web and Database Security****Time:02:30 PM TO 05:00 PM****Total Marks:70****Instructions:**

1. Attempt all questions.
2. Make suitable assumptions wherever necessary.
3. Figures to the right indicate full marks.

- Q.1** (a) (1) Mention any six password management guidelines for maintaining user accounts in organizations. [3]
(2) Which operations cannot be performed on database links? [4]
(b) Explain HTTP response message with suitable example [7]
- Q.2** (a) What do you mean by access control? Differential between (i) discretionary access control and (ii) role-based access control [7]
(b) Explain DOM-based XSS attack with all steps. [7]
- OR**
- (b) Explain stored XSS attack with all steps. [7]
- Q.3** (a) Differentiate between informed XPath injection and blind XPath injection with suitable example. [7]
(b) (1) Write one example of each of following signature of common vulnerabilities in application code base. [6]
(i) cross-site scripting (ii) backdoor password (iii) path traversal
(2) Define: Fingerprinting the Database [1]
- OR**
- Q.3** (a) Give an example of how attacker performs injection into SMTP message? [7]
(b) What options are available with attacker to beat signature based filters? [7]
- Q.4** (a) In HTTP request message, [7]
What are the If-Modified-Since and If-None-Match headers used for?
Why might you be interested in these when attacking an application?
(b) (1) What is verbose failure message? Give an example. [3]
(2) How UNION SQL injection is performed in Oracle? Give suitable example. [4]
- OR**
- Q.4** (a) (1) Explain second order SQL injection with suitable example. [4]
(2) Give any three examples of granting database system privileges. [3]
(b) Related to following services, list down JAVA APIs that can introduce security vulnerabilities if used in an unsafe manner. [7]
(i) file access (ii) database access
- Q.5** (a) What are compliance mandates for database security? [7]
(b) Show a SSL checklist for networking security. [7]
- OR**
- Q.5** (a) Explain workflow system architecture in detail with suitable example. [7]
(b) Why source code audit is required in attacking a target web application? [7]
